# AI Security Deep Audit — Unpatched, Dangerous, Real

*Generated: 2026-10-31 | Method: Mirofish six-perspective adversarial reasoning*

---

## The Problem Companies Actually Face

Companies are deploying AI agents and MCP integrations that run with **production permissions**, read **internal documents**, and hold **API keys and database credentials**. The vulnerability surface is not theoretical — it is the agent's own toolchain, and 99.9% of known AI vulnerabilities with available fixes remain unpatched (Orca Security, July 2026).

The deepest weakness is **not a single CVE**. It is the architecture: agents trust untrusted data, MCP servers run with the user's privileges, and the gap between approval and runtime behavior has no verification layer.

---

## Layer 1: The Unpatched Kill List (No Fix Exists or Fix Is Unclear)

These are the CVEs where companies are **currently exposed and cannot simply patch**.

### CVE-2026-77932 — DB-GPT Unauthenticated RCE as Root

- **Product:** DB-GPT through 0.8.2
- **CVSS:** 9.3 (v4.0) / 9.8 (v3.1)
- **Status: No patched version exists.** Latest release IS 0.8.2, the vulnerable version.
- **Mechanism:** Mock `get_user_from_headers` grants every caller admin role. Unauthenticated prompt triggers unsandboxed `code_interpreter` and `shell_interpreter` running Python/bash as root. Bundled MySQL reachable with default credentials.

- **Company risk:** Any company running DB-GPT for internal AI tools is one HTTP request from full container compromise. No auth, no sandbox, root shell.
- **Audit weapon:** `curl -X POST http://target/api/v1/chat/react-agent` with a prompt that calls code_interpreter. If it returns a command result, you are in.

## CVE-2026-92206 — CrewAI Unsafe Reflection RCE (ZDI Zero-Day)

- **Product:** CrewAI Framework
- **CVSS:** 8.8
- **Status: No patched version named.** Vendor unresponsive for 11 months (reported Oct 2025, published Sep 2026). GHSA lists no fix. PyPI latest is 1.15.22 with no changelog reference.
- **Mechanism:** `load_agent_from_repository` does not restrict user-supplied argument before importing a module. Loading a malicious agent config from a repo = RCE.
- **Company risk:** Any CrewAI workflow that loads agent definitions from Git repos, S3 buckets, or shared drives is exposed. The user interaction requirement is trivial in CI/CD pipelines.
- **Audit weapon:** Check `crewai` version. Check if agent configs are loaded from any path a prompt can influence.

## CVE-2026-75130 — Context7 MCP Prompt Injection (Upstash)

- **Product:** Context7 through 2.1.2 (Upstash MCP documentation server)
- **CVSS:** 9.0 (v3.1) / 6.4 (v4.0)
- **Status: Fix genuinely unclear.** npm shows 4.0.3 released 3 days after CVE, but release notes say “OAuth authorization-validation patch” — no mention of sanitization. CVE record names no fixed version.
- **Mechanism:** “Custom AI Instructions” feature serves unsanitized text into agent context during routine doc lookups. Demonstrated path: poisoned instruction → agent reads .env files → exfiltrates to attacker GitHub repo → deletes local folders.
- **Company risk:** ~4M downloads/month. Any developer using Cursor, Claude Code, or Windsurf with Context7 MCP is one documentation request from credential theft and workspace destruction.
- **Audit weapon:** Check installed `@upstash/context7-mcp` version. If <= 2.1.2, assume compromised.

## CVE-2026-4496 — Git-MCP-Server Command Injection

- **Product:** git-mcp-server
- **CVSS:** 5.3 (understated; practical impact is RCE)
- **Status: Vendor unresponsive as of March 2026.** Exploit publicly disclosed.
- **Mechanism:** OS command injection in `child_process.exec` within merge diff and file diff operations.
- **Company risk:** Any agent using git operations through this MCP server can have diff content weaponized into shell commands.

## CVE-2026-33626 — LMDeploy Cloud Metadata SSRF

- **Product:** LMDeploy
- **CVSS:** 7.5
- **Status: No patched version listed.** Actively exploited (Sysdig confirmed).
- **Mechanism:** Image URLs in chat requests reach cloud metadata endpoints (169.254.169.254) and internal services.
- **Company risk:** AWS/GCP/Azure metadata theft = IAM credential exfiltration = full cloud account compromise.

## CVE-2026-75128 — Langchain-Chatchat Unauthenticated RCE

- **Product:** Langchain-Chatchat through 0.3.1.3
- **CVSS:** 9.3/9.8
- **Status: No patched version referenced.**
- **Mechanism:** `/tools/call` endpoint allows unauthenticated tool execution.
- **Company risk:** Direct RCE on any exposed deployment.

## CVE-2026-109442 — PiFlow DeepAgents Unauthenticated RCE

- **Product:** PiFlow 2.0.0-2.0.1
- **CVSS:** 9.3/9.8
- **Status: No patched version.**
- **Mechanism:** `POST /chat` and `/chat/stream` drive a DeepAgents agent whose `exec_shell` tool has no approval or allowlist.
- **Company risk:** Any internal data pipeline using PiFlow is a shell.

### CVE-2026-114107 — HKUDS Vibe-Trading Agent Root Execution

- **Product:** HKUDS Vibe-Trading 0.1.0 before 0.1.7
- **CVSS:** 8.7
- **Status:** Fixed in 0.1.7, but widely deployed trading agents may lag.
- **Mechanism:** Instructions planted in documents/web pages the agent reads lead to shell commands as root. URL tool allows SSRF.
- **Company risk:** Trading/finance AI agents reading market reports = compromised host.

---

# Layer 2: The Architectural Kill List (No Patch Will Ever Fix These)

These are not bugs. They are the design of the AI agent stack.

## Tool Poisoning (OWASP MCP03:2025)

- **Mechanism:** MCP server embeds malicious instructions in tool descriptions. Agent reads `tools/list` at session init, incorporates instructions into context, follows them as trusted commands.
- **Scale:** 200,000+ vulnerable MCP servers estimated in April 2026. MCPTox benchmark shows 72.8% tool poisoning success despite validation.
- **Company risk:** Any MCP server the company did not write and sign is a potential supply chain attack. The agent will obey poisoned tool descriptions before any user interaction.
- **No patch.** Requires allowlisted server registry, runtime content scanning, and agent-side guardrails.

## Rug Pulls

- **Mechanism:** Tool description or behavior silently altered after user approval. No new approval flow triggered.
- **Company risk:** A benign MCP server becomes malicious overnight. The company’s approval log is clean; the agent is compromised.
- **No patch.** Requires continuous behavioral fingerprinting of tool responses.

### Confused Deputy / Agentjacking

- **Mechanism:** Agent granted real privileges reads attacker-controlled content (GitHub issues, PRs, docs, web pages) and leaks through legitimate channels.
- **Confirmed:** Invariant Labs GitHub MCP exploit — agent exfiltrated private repo contents via malicious GitHub issue. Hugging Face intrusion during OpenAI evaluation.
- **No patch.** Requires identity controls and egress baselining per agent.

### Default Permission Bloat

- **Mechanism:** 81.2% of companies running AI packages have at least one known vulnerability. Agents run with default permissions, no logging, no runtime separation from production.
- **Company risk:** One compromised agent becomes a lateral movement pivot through the entire AI layer.

---

## Layer 3: Active Threat Intelligence (Last 30 Days)

### Storm-0940 / ARTEX (Microsoft, Oct 21 2026)

- **Actor:** China-state aligned
- **Tool:** ARTEX open-source penetration testing framework (multi-agent LLM system)
- **Speed:** <3 hours from initial targeting to privileged cloud access
- **Impact:** Hundreds of organizations globally. ConnectWise supply chain compromise attributed.
- **Company risk:** Any company using AI-powered pentest tools or exposed agent APIs is in the blast radius. The actor is automating reconnaissance and privilege escalation at machine speed.

### Lasso Security October 2026 Wave (6 CVEs, 5 Unpatched)

- **Products:** DB-GPT, Langchain-Chatchat, PiFlow, EvoScientist, LangAlpha, OpenSRE
- **All:** Unauthenticated RCE or critical severity. 5 of 6 have no patched version.
- **Company risk:** Self-hosted AI agent platforms are being harvested in bulk.

---

# Layer 4: Supply Chain Nightmares

## LiteLLM PyPI Compromise (March 2026)

- **Impact:** Backdoor sat on PyPI for 3 hours, 47,000 downloads. Used by CrewAI, DSPy, Microsoft GraphRAG.
- **Status:** Compromised releases pulled, but downstream dependency graphs still reference them.
- **Company risk:** Any `pip install` during that window pulled an autonomous attack bot.

## OpenClaw ClawHub (January-February 2026)

- **Impact:** 1,184 malicious skills uploaded (~12% of registry). 135,000 exposed instances.
- **Status:** 9 CVEs, 3 with public exploit code.
- **Company risk:** Agent skills marketplaces are unvetted supply chains.

---

# Layer 5: The Numbers That Should Terrify CISO

| Statistic | Source |
|---|---|
| 81.2% of companies running AI packages have ≥1 known vulnerability | Orca Security |
| 74.1% have ≥1 critical CVE | Orca Security |
| 99.9% of fixable AI vulnerabilities remain unpatched | Orca Security |
| 200,000+ MCP servers exposed unauthenticated | April 2026 advisory |
| 1,500+ AI-related CVEs in 2026 alone | GTIG |
| 782 of those in AI orchestration & agent frameworks | GTIG |
| Zero-day exploitation rose from 8/month to 22/month in August 2026 | GTIG |
| 43% of tested MCP servers had command injection | Equixly |

---

# Mirofish Six-Perspective Synthesis

## Perspective 1: Threat Evolution

The attack surface is shifting from model-level (prompt injection) to infrastructure-level (framework RCE, MCP server poisoning, supply chain). The bugs are 20-year-old classes (SQL injection, deserialization, path traversal) reintroduced into agent frameworks. This means **legacy security tooling can detect them** — but nobody is looking at the AI layer yet.

## Perspective 2: Detection Future

Current detection fails because agent abuse rides on **legitimate functionality**. Traditional exploit signatures do not fire. The Hugging Face intrusion and GitHub MCP exfiltration both used normal API calls. Without per-agent egress baselines and MCP response content scanning, these are invisible.

## Perspective 3: Attack Surface

The blast radius of one unpatched MCP server is not that server — it is every agent that connects to it, every secret that agent can read, and every system that agent can reach. A single poisoned Context7 documentation request can exfiltrate every `.env` file in a project.

## Perspective 4: Defensive Posture

Companies are: - Not patching (99.9% unpatched rate) - Not isolating agents from production - Not scanning MCP tool responses - Not allowlisting MCP servers - Not rotating credentials that agents can read - Not monitoring agent egress

## Perspective 5: Simplicity Guard

The sentinel approach works because it reduces the problem to three questions: 1. Is this CVE in the AI/agent/MCP keyword set? 2. Is it in CISA KEV (actively exploited)? 3. Does my lockfile reference the affected package?

Everything else is noise reduction.

### Perspective 6: Evidence Trail

Every finding above is sourced to: - NVD / CVE Services (cveawg.mitre.org) - CISA KEV catalog - FIRST EPSS - Vendor advisories and GHSA - Researcher disclosures (Lasso Security, Noma Security, Check Point, VulnCheck, ZDI)

---

# Cost of Inaction: What These Vulnerabilities Actually Cost You

**These are not theoretical. Each unpatched vulnerability below has a confirmed exploitation path or public exploit code.**

## If you do nothing

| Scenario | Likely cost |
|---|---|
| **Full system compromise via unpatched RCE** — DB-GPT, CrewAI, Context7 MCP all have unpatched critical CVEs | £500K–£5M (breach + incident response) |
| **State-actor access** — Storm-0940 reaches privileged cloud in <3 hours | £2M–£50M (IP theft + regulatory + reputational) |
| **Supply chain compromise** — malicious PyPI packages, poisoned MCP skills, backdoored dependencies | £1M–£10M (downstream customer impact + brand damage) |
| **Regulatory action** — NIS2, GDPR, DORA, ISO 42001 non-compliance discovered post-incident | £200K–£10M (fines + mandatory audits + certification loss) |
| **Operational disruption** — agent workflows halted for forensic investigation | £50K–£500K (lost productivity + incident response) |

**The audit starts at £8,000. A single breach starts at £500,000.**

**Hypothesis:** If your organisation runs ANY AI agent framework (LangChain, CrewAI, Langflow, AutoGen, MCP servers), the expected value of doing nothing is massively negative. The 99.9% unpatched rate means you are the norm, not the exception. Attackers know this.

**What changes with an audit:** - You know exactly which CVEs affect YOUR stack, not a generic list - You have a verified remediation path sized to your risk appetite - You can show your board/CISO a dated technical report with CISA KEV + EPSS + exploit evidence - You stop hoping and start knowing

---

# What This Means for Twinthos Monetisation

## Immediate Audit Targets (This Week)

1. **Any company running DB-GPT** — full compromise risk, no patch. Sell emergency lockdown + migration.
2. **Any company using CrewAI in production** — zero-day with no fix. Sell agent config audit + sandboxing.
3. **Any company with Context7 MCP in dev environments** — credential exfiltration risk. Sell MCP server audit + allowlist policy.
4. **Any company with exposed MCP servers** — 492 unauthenticated found by Trend Micro. Sell attack surface mapping.

## Systems to Build

1. **MCP Lockfile Scanner** — extend sentinel to scan `package.json`, `requirements.txt`, `pyproject.toml` against AI/agent/MCP CVE feeds. This is the gap nobody is filling.
2. **Agent Egress Monitor** — baseline what your AI agents are calling and alert on anomalous destinations.
3. **MCP Server Allowlist Policy** — governance layer that approves servers before agents can connect.

## The Pitch

“You have agents running in production with default permissions, reading your internal documents, and holding your API keys. 99.9% of known AI vulnerabilities in your stack are unpatched. I don’t sell you a SaaS dashboard. I audit your agent framework,

your MCP servers, and your lockfiles, then I build you a continuous monitor that runs locally and alerts you before the next DB-GPT-style RCE.”

---

**What to watch in generic infrastructure CVE feeds**

cvedotnow tweet (Oct 30, 2026) on CVE-2026-116366 (ClickHouse RCE): - 321.8K views, 890 reposts — this is what generates engagement - Format that works: severity emoji + product + CVE ID + mechanism + patch versions - ClickHouse is not an “AI product” but it is widely used for AI analytics, agent memory, and ML pipelines - Our sentinel’s pure-AI filter would miss this — but a company running ClickHouse for AI workloads needs to know

**Learning applied to sentinel:** Two-tier keyword filter (committed as 1367cb1): - Tier 1: direct AI/agent/MCP keyword → flag - Tier 2: AI infrastructure keyword (clickhouse, qdrant, pinecone, redis, elasticsearch, etc.) → only flag if AI keyword ALSO present in same entry

This catches “ClickHouse RCE in AI pipeline” without flagging every generic database CVE.

**Audit quality signal from @CloakdDev (Oct 2026):** - “One word - Rushed. 154 audit findings is crazy high & even after fixes does not guarantee no side effects from the changes made.” - “Most findings in old code sadly” - **Learning:** High-volume audit reports signal low-quality, rushed work. The market trusts focused findings over sprawling lists. Twinthos positioning: “3-5 exploitable paths, not 154 noise items.” This differentiates from commodity auditors who maximize billable hours by surface-area.

**Twinthos audit philosophy (from this signal):** - Surface only AI/agent/MCP-relevant findings - Prioritize by CISA KEV + EPSS + exploitability - Provide smallest effective fix, not rewrites - Test fixes for side effects before declaring remediation - Avoid padding with old-code findings that aren’t in scope